Spécification des mécanismes de sécurité

Chaque contrôle est rattaché à un fichier. Le détail opérationnel des incidents est dans le guide d'exploitation.

Identité et session

Contrôle	Tenue
Mots de passe	PBKDF2-SHA256, 200 000 tours. Jamais relus en clair, jamais écrits dans l'audit
Connexion	Adresse e-mail ou identifiant. Un compte supprimé logiquement ou inactif ne se connecte pas
Jeton	HMAC, durée 8 heures, cookie httpOnly. Le sujet du jeton est l'identifiant stocké
Inactivité	Gestionnaire et administrateur déconnectés après 15 minutes
Débit	Limite sur la connexion et les routes d'administration (`RATE_LIMIT_LOGIN`, `RATE_LIMIT_ADMIN`)
Mot de passe oublié	Pas d'envoi. Un administrateur réinitialise le compte
Changement	Mot de passe actuel, nouveau, confirmation. Le succès est audité sans le secret

Séparation des accès

L'API n'est pas superutilisateur. Elle utilise `prediccare_app`.

L'assistant utilise `prediccare_agent` : `SELECT` seulement, sur l'assuré dont le pseudonyme est posé dans la session. Le texte de la question ne choisit pas cet identifiant. Les schémas `identites`, `raw` et `labels` ne lui sont pas ouverts.

Le tableau Superset utilise `prediccare_bi`, lecture seule du schéma `bi`, sans labels ni identités.

La ré-identification et l'effacement exigent l'en-tête `X-Admin-Key`. Ils passent par des fonctions, pas par une lecture directe du coffre. L'audit garde le pseudonyme et le résultat, pas le nom.

Données

Contrôle	Tenue
Pseudonyme	HMAC. Le schéma `clean` n'a pas l'année de naissance
Coffre	Chiffrement des identités. Clé dans l'environnement
Chargement	Échec si un e-mail, un téléphone, un CIN ou un nom complet est trouvé dans `clean`
Score	Refus du pipeline si une colonne interdite est présente (`est_fraude`, identité, décision)
Facture invalide	Code et motif, statut 422, aucun score, aucun 500
Identifiant de facture	Rejeté s'il porte une injection
OCR	Ni nom, ni adresse, ni téléphone, ni e-mail, ni CIN conservés
Journaux	Heure, chemin, statut, durée. Pas de corps de facture, pas de jeton
Alerte	Score, seuil, version, contributions. Pas de nom
Sauvegarde	`db/backup/backup.sh` et `restore.sh`. Le volume Docker n'est pas une sauvegarde

Assistant

Une question hors remboursements et garanties est refusée avant l'appel au modèle. Le filtre d'injection bloque une consigne qui tente de sortir de ce périmètre. La réponse cite la source. L'historique lu est celui de l'assuré du jeton. Les conditions particulières ne sont lues que pour son contrat. Une question proche est servie depuis le cache sémantique.

La requête vers la base n'est pas affichée. Elle n'est pas composée librement à partir du texte : les lectures passent par le rôle limité à la session.

Modèle

Deux artefacts versionnés, `v1` et `v2`, 23 variables, scikit-learn 1.9.1. La bascule se fait par réglage, sans arrêt de l'API. Un artefact inutilisable répond `MODELE_INDISPONIBLE` et n'enregistre pas la facture.

Le seuil d'alerte n'est pas écrit dans le code du score. La valeur d'exemple 0,8 du cahier n'est pas celle qui classe.

Dépendances et secrets

Les secrets sont dans `.env`, ignoré par git. `.env.example` n'a pas de vraie clé. Les dépendances Python sont épinglées et auditées en intégration continue. Les requêtes de l'API sont paramétrées.

Menace résiduelle

Compromettre le compte propriétaire de la base expose `raw`, qui contient encore les fichiers sources. Compromettre `LLM_API_KEY` permet d'appeler le modèle de langage au nom du projet. Une combinaison rare d'actes peut réduire le groupe d'un pseudonyme même sans nom. Ces trois points se traitent par l'accès au serveur, la rotation de la clé, et l'audit d'équité décrit dans le dossier de conformité.